

Architecture & Security Peer Review

Roujaune — personalised cycling training for riders 50+ | Formal pre-production review | Read-only (no code modified)

Production Verdict

Requires Significant Changes — Not Ready

Verification method & scope. Read-only static review of the current worktree plus two independent sub-audits (functional/architecture and security/privacy). **No code was changed.** [CONFIRMED] = backed by cited code; [LIKELY] = needs runtime confirmation. This preview environment has no CI/CD, load/DR/backup infra, device lab, or 50+ tester panel, so areas 30–39 are assessed from code + config only and infra/human items are marked *Unable to verify (needs operational validation)*.

A. Executive Summary

Architecture C+: sound Expo ↔ FastAPI ↔ MongoDB separation, good per-user scoping proxy and Fernet-encrypted OAuth tokens, but a 4,270-line **server.py monolith** with business logic (incl. the benchmark decision engine) in route handlers. **Code quality C+:** modular helpers + ~30 backend pytest files, but untyped Dict[str,Any] bodies, magic numbers, and no tests for the coaching/benchmark decision logic. **Production: Requires significant changes** — two confirmed HIGH defects plus privacy gaps block release for a health app serving over-50s.

Five strongest aspects (preserve)

- Per-user isolation via `_ScopedDB` + manual `user_id` filters; benchmark `:sid/:rid` endpoints re-check ownership (audit PASS).
- Daily readiness gating screens critical symptoms (readiness.py CRITICAL_SYMPTOMS: chest pain, dizziness, SOB, illness, new pain).
- Shared coach intelligence — `coach_system(name, gender)` parametrises persona; no duplicated engine.
- OAuth tokens encrypted at rest (Fernet); client tokens in SecureStore (not AsyncStorage).
- LLM “adjust my plan” writes constrained by a `sanitize_ops` allow-list rather than trusting model output.

Five highest-risk issues

- **[HIGH/CONFIRMED] Cross-tenant plan mutation** — any rider can PUT/PATCH/DELETE `/api/plans/{id}` (`plans_admin.py:152-177`); `plans` collection is global; no admin role.
- **[HIGH/CONFIRMED] Dead benchmark safety triggers** — illness/injury/return/equipment branches (`server.py:1435-1449`) read top-level check-in fields but data persists nested under `doc['checkin']`; frontend never collects them → never fire.
- **[HIGH/CONFIRMED] Benchmark decision engine incomplete/route-embedded/untested** (`server.py:1420-1484, 1727-1795`).
- **[MEDIUM/CONFIRMED] Privacy gaps** — no account deletion/export; health data to third-party LLM without consent (`server.py:2311-2369`).
- **[MEDIUM/CONFIRMED] Secrets not git-ignored** — `backend/.env` not in `.gitignore` (untracked but at risk).

Immediate direction (no rewrite): (1) admin-gate `/api/plans/*`; (2) fix benchmark check-in field path + collect missing questions; (3) extract deterministic, unit-tested `BenchmarkDecisionService`; (4) `.gitignore .env` + rotate; (5) add deletion/export/consent.

B. Architecture Map

- **Layers:** Expo Router screens → `src/lib` services (+ SecureStore token, global-fetch bearer) → FastAPI `AuthMiddleware` → `api_router` + sub-routers → `_ScopedDB` → MongoDB. LLM via emergentintegrations.
- **Coaching flow:** rider context → `coach_system(name,gender)` prompt → LLM → display copy. Chat “adjust plan” → `sanitize_ops` allow-list → `plans_admin.adapt_plan`.
- **Benchmark-decision flow:** `benchmark_plan_gate` → `_benchmark_recommendation` + `BM_*` tables → `status(required|recommended|approved|submaximal)` → `week (_default_week_days, _maximal_spacing_ok)`.
- **External:** Emergent LLM / Google & Apple OAuth / Email / Push; Garmin + Google Fit (`activity_sync.py`); Open-Meteo (keyless).

C. Findings Register

F-01	Any rider can edit/delete shared training plans	High	AuthZ / BFLA	plans_admin.py:152-177; server.py:2960-2971	Admin-role gate; per-user plan copies for rider edits.	M	Yes
F-02	Benchmark illness/injury/equipment retest triggers are dead code	High	Functional / Safety	server.py:1435-1449; checkin.ts:18-24	Read nested checkin (or persist flat) + add questions.	S	Yes
F-03	Benchmark decision engine incomplete, route-embedded, untested	High	Architecture	server.py:1420-1484, 1727-1795	Extract deterministic BenchmarkDecisionService + unit tests.	M	Yes
F-04	Coach identity 'Alberto' leaks under Adriana	Medium	Content / Product rule	calendar.tsx:385,387; summary.ts:67; PlanReviewCard.tsx:13,77	Thread useCoach() persona; remove literal defaults.	S	Before prod
F-05	Accepting an older benchmark overwrites current FTP	Medium	Data integrity	server.py:1267-1284, 1311/1327	Apply only if newest-accepted per metric.	S	No
F-06	Benchmark collections not in USER_SCOPED; no per-user indexes	Medium	AuthZ / Perf	auth.py:40-45,118-126,212-217	Add to USER_SCOPED; create user_id/id indexes.	S	No
F-07	No account deletion/export; health data to AI w/o consent	Medium	Privacy (GDPR)	server.py:2311-2369,2408	Add erasure+export endpoints; AI data-sharing consent.	M	Before prod
F-08	backend/.env not git-ignored	Medium	Secrets / Misconfig	.gitignore (no .env rule)	Add ignore rule; rotate on exposure.	S	Before prod
F-09	Coach LLM session_id not per-user	Medium (Likely)	AuthZ / BOLA	server.py:787,890,989,1409 ...; companion_plan.py:115	Include user_id in every session_id.	S	Before prod
F-10	Push registration trusts client user_id	Medium	AuthZ / BOLA	push.py:50-64	Derive user_id from session; ignore body.	S	Before prod
F-11	Client-side benchmark calc trusted verbatim by server	Medium	Integrity	calc.ts:130; create_benchmark_result	Server-side recompute/validate + bounds.	M	Next cycle
F-12	Wildcard CORS with credentials	Low	Misconfig	server.py:4201-4207	Explicit allow-list origins.	S	Next cycle
F-13	Weak auth controls (6-char, no rate-limit, soft-verify, 409 enum)	Low	Auth hardening	auth.py:312,496,310-311,317-324	Rate-limit + strength policy; neutral responses.	M	Next cycle
F-14	server.py monolith + untyped bodies + date F821	Low/Info	Maintainability	server.py (4270 LOC); L1607	Routers/services split; Pydantic models.	L	Next cycle
F-15	Activity dedup lookup omits user_id	Low	Isolation	activity_sync.py:113	Scope by user_id.	S	Next cycle

Cx = complexity (S/M/L). Blocks = blocks production release.

D. Code-Level Review (selected)

F-03 — *extract the decision (pattern)*

Problematic: decision + LLM copy inside the route (server.py:1421-1484). Recommended: a pure, testable service returning {status, reason, evidence[], recommendedTestType, confidence}; the route stays thin and the LLM only phrases decision.reason for display. Improvement: deterministic, unit-testable, auditable.

F-02 — field-path bug: gate reads checkin.illness, but writes land under checkin['checkin'][...]. Read the correct nested path (or persist flat) and add the questions to checkin.ts.

F-01 — role gate: plans_admin routes need Depends(require_admin); rider-initiated changes should target a per-user plan instance, not the shared definition.

E. Training & Benchmark Assessment

- Personalisation: level classifier (rider_level.py) + benchmark-aware gate exist. 'Advanced as default' — **Unable to verify** (no code path asserts it).
- Progression/recovery: 'no two maximal tests on consecutive days' enforced (_maximal_spacing_ok) — good. Broader load-escalation caps not evidenced server-side.
- Benchmark validity/retesting: recency thresholds present, but continuity, performance-change, direct-progression and structured confidence are missing (F-03); illness/equipment triggers dead (F-02).
- Data-confidence: computed client-side and trusted (F-11); no server bounds.
- Illness/injury: strong at daily-readiness layer (readiness.py); absent at benchmark layer.
- Explainability: free-text reasons + warm LLM copy, but not structured evidence/confidence for audit.
- ■ Requires independent sports-science sign-off (not automatable here): progression/recovery/workload limits, return-to-training, FB50 age adaptations. Software verification ≠ coaching validation.

F. Security Assessment (STRIDE)

- **Spoofing:** push user_id spoofing (F-10); OAuth auto-trust of provider email.
- **Tampering:** shared-plan mutation (F-01); client-supplied benchmark metrics (F-11).
- **Repudiation:** no audit log for plan/admin actions (no admin role exists).
- **Info disclosure:** health data → third-party LLM w/o consent (F-07); potential cross-user LLM memory (F-09); .env exposure risk (F-08).
- **DoS:** no rate limiting (F-13); no size caps on base64 avatar uploads.
- **Elevation:** no RBAC — every rider has admin-level plan power (F-01).

Authorization matrix (as-built)

Own profile / rides / benchmarks / check-ins	No	Yes (scoped, verified)	role does not exist
Another rider's data	No	No (correctly blocked)	—
Create/replace/delete SHARED plans	No	YES — defect F-01	—
Register push token for arbitrary user	No	Yes — defect F-10	—

Community (/api/community) = static read-only demo data → no UGC/report/block/moderation → trust-&-safety **not implemented**.

Subscriptions/payments: **none exist** → **N/A**.

G. Testing Assessment

- Current: ~30 backend pytest files (auth/multi-user isolation, benchmark CRUD, calendar, ride-sync, prefs) + 2 frontend script tests — good CRUD breadth.
- Major gaps: benchmark DECISION logic; workout progression; illness/injury adaptation; Alberto↔Adriana consistency; calc numerical correctness; property/invariant tests.
- Priority edge cases: new rider (no benchmark); direct plan→plan (no auto-repeat); recent vs expired benchmark; return after illness/injury; bike/power-meter change; no power meter; incomplete HR; missed workouts; over-training; declining performance; Intermediate→Advanced; conflicting fitness data.
- Architecture: pure-function services → fast table-driven unit tests; API/integration vs ephemeral Mongo; a coaching-eval suite re-run on any prompt/model/rule change and diffed vs an approved baseline.

H. Prioritised Action Plan

Fix immediately (blocks prod)

- F-01 admin-gate /api/plans/* (~0.5–1d) — prevents cross-tenant plan destruction.
- F-02 benchmark check-in field path + questions (~0.5d) — restores safety retests.
- F-03 extract BenchmarkDecisionService + unit tests (~2–3d) — auditable, correct decisions.

Fix before production

- F-07 deletion/export + consent (~2–3d); F-08 .gitignore + rotate (~1h); F-09 per-user session_id (~0.5d); F-10 push user_id from session (~0.5h); F-04/F-05/F-06 coach leaks, FTP recency guard, USER_SCOPED+indexes (~1–2d).

Next development cycle

- F-11 server-side calc validation; F-12 CORS allow-list; F-13 rate-limit + password policy; coaching-eval + property tests; begin server.py router/service split (F-14).

Longer-term

- Migration framework; observability/audit logging (no PII); activity-import fuzzing (FIT/TCX/GPX untrusted input); feature flags for AI/plan-gen/sync; SBOM + dependency scanning in CI.

I. Final Production-Readiness Verdict

Requires significant changes — Not ready for production. Two CONFIRMED HIGH defects affect safety and multi-tenant integrity for a health app serving over-50s: (F-01) any rider can rewrite/delete the plan others follow, and (F-02) illness/injury/equipment benchmark-retest safeguards never execute — compounded by (F-03) an unaudited/untested decision engine and (F-07) missing privacy controls. The foundation is solid (good isolation, encrypted tokens, strong daily-readiness gating, shared coach engine), so these are incremental fixes, not a rewrite. After the 'Fix immediately' + 'Fix before production' batches and independent sports-science sign-off, this could move to 'Ready with minor changes'.

Not verifiable in this environment (need operational/human validation): 22 device/FIT-file fuzzing, 23 live sandbox contract tests, 24 migration/rollback on prod-sized data, 29 WCAG 2.2 AA with real 50+ users, 30 device matrix, 31 load/soak/battery, 32 chaos, 33 backup/DR restoration, 34 observability/on-call, 35 CI/CD controls, 36 SBOM/supply-chain, 38 feature-flag/rollback, 39 field UAT. No code was implemented as part of this review.